

06 – Datenschutz (DSGVO) und Informationssicherheit (BSI-Grundschutz)

Stand: September 2026. Diese Prüfung bewertet den Carcura Manager gegen die DSGVO, das BDSG und die technischen Bausteine des BSI-IT-Grundschutz-Kompendiums (u. a. APP.3.1 Webanwendungen, APP.4.3 Relationale Datenbanken, ORP.4 Identitäts- und Berechtigungsmanagement, CON.3 Datensicherungskonzept, OPS.1.1.5 Protokollierung, SYS.2.1 Allgemeiner Client). Sie ersetzt keine Rechtsberatung und kein Datenschutz-Audit. **Vollständige Konformität ist nie allein durch Software erreichbar:** Verträge, Informationstexte, Verzeichnisse und Organisationsregeln (Teil C) müssen vom Betrieb ausgefüllt werden.

A. Ergebnis in einem Satz

Die technischen Anforderungen sind umgesetzt und getestet (Teil B). Offen sind ausschließlich organisatorische Pflichten, die nur Carcura selbst erfüllen kann (Teil C). Zwei technische Punkte hängen von der Betriebsart ab: Festplattenverschlüsselung des Laptops (BitLocker) und HTTPS, sobald das System aus dem Internet erreichbar ist.

B. Technische Anforderungen – Status

Anforderung	Rechtsgrundlage / Baustein	Umsetzung im System	Status
Passwörter nie im Klartext	Art. 32 DSGVO, ORP.4	script (N=65536), Mindestlänge 10, Groß/Klein/Ziffer, Sperre nach 5 Fehlversuchen für 15 Minuten, gleiche Antwortzeit bei unbekannter E-Mail	erfüllt
Mehrfaktor-Authentifizierung	ORP.4.A21 (empfohlen), Art. 32	TOTP (RFC 6238) je Benutzer, 10 Wiederherstellungscodes (nur Hashes gespeichert), Geheimnis AES-256-GCM verschlüsselt, Option „2FA für Administratoren erzwingen“, Admin-Reset bei Geräteverlust	erfüllt
Sitzungen	ORP.4, APP.3.1.A7	serverseitige Sitzungen, signiertes httpOnly-Cookie, SameSite=Lax, Secure bei HTTPS, Leerlauf 8 h, maximal 30 Tage, Widerruf bei Logout/Passwortwechsel, tägliche Bereinigung	erfüllt
Rollen und Berechtigungen	Art. 25/32, ORP.4.A2	5 Rollen, je Rolle einzeln konfigurierbare Rechte, Prüfung serverseitig je Route, Mandantentrennung über <code>company_id</code> in jeder Tabelle	erfüllt
Protokollierung von Änderungen	Art. 5 Abs. 2 (Rechenschaft), OPS.1.1.5	Audit-Log mit Benutzer, Aktion, Objekt, Vorher/Nachher, IP; nicht über die Oberfläche löschtbar; Aufbewahrung konfigurierbar (Standard 24 Monate)	erfüllt
Verschlüsselte Ablage von Zugangsdaten Dritter	Art. 32	SMTP, API-Schlüssel, 2FA-Geheimnisse mit AES-256-GCM; Schlüssel in <code>data/app-secret.key</code> (0600) oder <code>APP_SECRET</code> ; nie an den Browser	erfüllt
Transportverschlüsselung	Art. 32, APP.3.1.A5	Lokal im WLAN: HTTP zulässig. Bei <code>PUBLIC_URL=https://...</code> : Secure-Cookies und HSTS automatisch. Zertifikat liefert Tunnel oder Reverse Proxy	erfüllt, betriebsabhängig
Sicherheits-Header	APP.3.1	Content-Security-Policy (nur eigene Quellen), X-Frame-Options, nosniff, Referrer-Policy, Permissions-Policy, COOP	erfüllt
Schutz vor Brute-Force / Missbrauch	APP.3.1.A14	Rate-Limits auf Login, 2FA, Einrichtung, Website-Formular, KI-Anfragen; Honeypot im Website-Formular	erfüllt
Eingabevalidierung, Datei-Uploads	APP.3.1.A4/A6	Zod-Schemata für jede Route, Uploads nur JPG/PNG/WebP/PDF bis 25 MB, Bilder werden neu kodiert, Pfade gegen Directory-Traversal geprüft	erfüllt
Auskunftsrecht (Art. 15) und Datenübertragbarkeit (Art. 20)	Art. 15, 20	Kundenakte → Export: vollständige Auskunft als JSON (Stammdaten, Fahrzeuge, Leads, Historie, Termine, Aufgaben, Aufträge, Angebote, Rechnungen, Zahlungen, Protokolle, Dateiliste, E-Mails, Verantwortlicher, Auftragsverarbeiter)	erfüllt

Anforderung	Rechtsgrundlage / Baustein	Umsetzung im System	Status
Recht auf Löschung (Art. 17) mit Aufbewahrungspflichten	Art. 17 Abs. 3 lit. b, § 147 AO, § 14b UStG	Löschkonzept: ohne Belege vollständige Löschung; mit Belegen Anonymisierung (Kontaktdaten, Notizen, Historie, Aufgaben, Fotos, Unterschriften, Protokoll-PDFs entfernt; Rechnungen/Angebote/Aufträge unter Pseudonym erhalten); Audit-Einträge ohne Personenbezug	erfüllt
Speicherbegrenzung (Art. 5 Abs. 1 lit. e)	Art. 5, 25	täglicher Aufbewahrungslauf: verlorene Leads (12 Monate), unbeantwortete Leads (24 Monate), Versandprotokoll (12), Audit-Log (24), Job-Protokoll (90 Tage), optional inaktive Kunden (Jahre); alle Fristen einstellbar	erfüllt
Datenminimierung bei KI-Nutzung (Drittland)	Art. 25, 44 ff.	KI-Assistent erhält standardmäßig nur Kennzahlen und Kundennummern, keine Namen/Kontaktdaten; Freigabe nur bewusst per Einstellung; kein Dokumentinhalt, keine Fotos	erfüllt
Privacy by Default	Art. 25	KI-Personenbezug aus, Website-Formular nur mit Token, Lead-Quelle ohne Tracking-IDs verarbeitbar, keine Cookies außer Sitzung	erfüllt
Datensicherung	CON.3	täglich 02:30, manuell, Aufbewahrung 14 automatische + 20 manuelle, Wiederherstellung mit Sicherheitskopie, Prüfung der Sicherung beim Einspielen	erfüllt
Verschlüsselung ruhender Daten	Art. 32, SYS.2.1	Datenbank und Dateien liegen unverschlüsselt im Datenordner. Pflicht: Geräteverschlüsselung (Windows BitLocker / macOS FileVault) und verschlüsselter Cloud-Speicher für Sicherungskopien	organisatorisch
Updates	OPS.1.1.3	Update aus der Oberfläche mit Sicherung davor; Abhängigkeiten über npm; <code>npm audit</code> vor Releases	erfüllt
Mandantentrennung (White-Label)	Art. 28/32	jede Tabelle mit <code>company_id</code> , jede Abfrage gefiltert, Dateien je Mandant in eigenem Ordner, Sicherungen nur für Betreiber	erfüllt
Keine Cookie-Banner-Pflicht	§ 25 TDDDG	nur technisch notwendiges Sitzungscookie, kein Tracking, keine Dritthalte	erfüllt

Automatisierte Tests dazu: `server/test/privacy.test.ts` (Header, TOTP, 2FA-Ablauf, Anonymisierung, Aufbewahrung, Auskunft), `server/test/auth.test.ts`, `server/test/users.test.ts`.

C. Organisatorische Pflichten des Betreibers (Carcura)

Pflicht	Was zu tun ist	Vorlage
Verzeichnis von Verarbeitungstätigkeiten (Art. 30)	Für jede Verarbeitung Zweck, Kategorien, Empfänger, Fristen, TOM eintragen. Pflicht auch für kleine Betriebe, sobald regelmäßig Kundendaten verarbeitet werden.	Abschnitt D
Informationspflichten (Art. 13)	Kunden bei Erhebung informieren: auf der Website (Datenschutzerklärung), im Auftrags-/Annahmeprotokoll oder per Aushang in der Werkstatt.	Abschnitt E
Auftragsverarbeitungsverträge (Art. 28)	Mit jedem Dienst, der Personendaten im Auftrag verarbeitet: E-Mail-Anbieter (SMTP), Windsor.ai (Meta-Lead-Import), Anthropic (nur bei Freigabe personenbezogener Daten), Server-/Cloud-Anbieter, Backup-Cloud. Google Ads/Analytics: Google-Datenverarbeitungsbedingungen akzeptieren.	Abschnitt F
Drittlandtransfer (Art. 44 ff.)	Anthropic, Google, Meta: EU-US Data Privacy Framework prüfen bzw. Standardvertragsklauseln des Anbieters akzeptieren und dokumentieren.	Abschnitt F
Technische und organisatorische Maßnahmen (Art. 32)	Liste in Abschnitt G übernehmen, ergänzen um: BitLocker aktiv, Bildschirmsperre, Zutrittsregeln Werkstatt/Büro, Passwort-Manager, wer Administrator ist.	Abschnitt G
Löschkonzept	Fristen aus den Einstellungen „Konto & Datenschutz“ dokumentieren und jährlich prüfen.	Abschnitt H
Datenschutzbeauftragter	Erst ab in der Regel 20 Personen, die ständig mit automatisierter Verarbeitung beschäftigt sind (§ 38 BDSG). Für Carcura derzeit nicht erforderlich, aber Prüfung bei Wachstum.	–

Pflicht	Was zu tun ist	Vorlage
Meldung von Datenpannen (Art. 33/34)	Prozess festlegen: Wer meldet innerhalb von 72 Stunden an das BayLDA (Bayern) bzw. die zuständige Landesbehörde? Audit-Log und Sicherungen helfen bei der Analyse.	Abschnitt I
Mitarbeiter	Verpflichtung auf Vertraulichkeit (Art. 29, § 53 BDSG) schriftlich; eigene Benutzerkonten, keine geteilten Passwörter; Zugänge bei Austritt sofort deaktivieren.	–
Fotos von Fahrzeugen	Kennzeichen sind personenbezogen. Verwendung für Werbung (Instagram, Website) nur mit Einwilligung des Kunden oder verpixelem Kennzeichen.	Abschnitt E
Beim Verkauf an andere Betriebe	Carcura wird Auftragsverarbeiter für jeden Mandanten: AV-Vertrag mit jedem Kunden, TOM-Beschreibung, Subunternehmerliste. Vorher rechtlich prüfen lassen.	–

D. Verzeichnis von Verarbeitungstätigkeiten – Entwurf

Verantwortlicher: Carcura GbR (Anschrift, E-Mail, Telefon aus den Einstellungen). Alle Angaben sind Vorschläge und müssen vom Betrieb bestätigt werden.

Nr.	Verarbeitung	Zweck	Kategorien betroffener Personen und Daten	Rechtsgrundlage	Empfänger	Löschfrist	TOM
1	Anfragen (Leads)	Anbahnung von Aufträgen	Interessenten: Name, Kontaktdaten, Fahrzeug, Anfragetext, Herkunft (Website, Google Ads, Meta), Klick-Kennung	Art. 6 Abs. 1 lit. b (vorvertraglich), lit. f (Werbeauswertung)	keine; Import von Meta-Lead-Formularen über Windsor.ai	verloren: 12 Monate; unbeantwortet: 24 Monate; gewonnen: wird Kunde	G
2	Kundenverwaltung	Vertragsdurchführung, Kommunikation	Kunden: Stammdaten, Kontaktdaten, Fahrzeuge (Kennzeichen, FIN), Kommunikationshistorie, Notizen	Art. 6 Abs. 1 lit. b	E-Mail-Anbieter (Versand)	3 Jahre nach letztem Auftrag prüfen; Anonymisierung auf Anfrage sofort (Belege ausgenommen)	G
3	Termine und Erinnerungen	Terminorganisation	Kunden: Name, Telefon/E-Mail, Termin	Art. 6 Abs. 1 lit. b	E-Mail-Anbieter, WhatsApp (nur durch manuellen Klick des Mitarbeiters)	wie Nr. 2	G
4	Fahrzeugprotokolle mit Fotos und Unterschrift	Dokumentation des Fahrzeugzustands, Beweissicherung	Kunden: Fahrzeugdaten, Fotos (Kennzeichen), Unterschrift, Name	Art. 6 Abs. 1 lit. b, lit. f (Beweissicherung)	keine	bis Ablauf der Gewährleistung, spätestens 3 Jahre nach Auftragsende; auf Anfrage sofort	G
5	Angebote, Aufträge, Rechnungen	Abrechnung, Buchführung	Kunden: Name, Anschrift, Leistungen, Beträge, Zahlungen	Art. 6 Abs. 1 lit. b, lit. c (§ 147 AO, § 14b UStG)	Steuerberater (CSV-Export), Finanzamt	8 Jahre (Buchungsbelege, ab 2025) bzw. 10 Jahre (Rechnungen)	G
6	Marketing-Auswertung	Erfolgskontrolle von Werbung	keine direkt identifizierbaren Personen; aggregierte Kampagnenzahlen; Lead-Zuordnung über Nr. 1	Art. 6 Abs. 1 lit. f	Windsor.ai, Google, Meta (Abruf)	24 Monate	G

Nr.	Verarbeitung	Zweck	Kategorien betroffener Personen und Daten	Rechtsgrundlage	Empfänger	Löschfrist	TOM
7	KI-Business-Assistent	betriebswirtschaftliche Auswertung	standardmäßig nur Kennzahlen und Kundennummern; bei Freigabe Namen/Kontaktdaten	Art. 6 Abs. 1 lit. f; bei Personenbezug AV-Vertrag und Drittlandprüfung	Anthropic (USA/EU je Vertrag)	Verlauf: bis Löschung durch Benutzer	G
8	Benutzerkonten und Protokolle	Zugriffsschutz, Nachweis	Mitarbeiter: Name, E-Mail, Rolle, Anmeldezeiten, IP, Änderungen	Art. 6 Abs. 1 lit. f, § 26 BDSG	keine	Audit 24 Monate; Konto bis Austritt	G
9	Wettbewerber-Monitoring	Marktbeobachtung	Unternehmen (öffentliche Google-Profil); Einzelunternehmer möglich	Art. 6 Abs. 1 lit. f	Google Places API	24 Monate	G
10	Datensicherung	Verfügbarkeit	alle oben genannten	Art. 32	Backup-Speicher (extern/Cloud)	14 tägliche, 20 manuelle Sicherungen	G

E. Informationstext für Kunden (Art. 13) – Vorlage

Für Website-Datenschutzerklärung, Auftragsformular oder Aushang. Platzhalter ausfüllen.

Datenschutzhinweise der Carcura GbR Verantwortlich: Carcura GbR, [Straße], [PLZ Ort], [E-Mail], [Telefon]. Wir verarbeiten Ihre Daten (Name, Kontaktdaten, Fahrzeugdaten inklusive Kennzeichen, Fotos des Fahrzeugzustands, Ihre Unterschrift auf dem Protokoll, Angebots- und Rechnungsdaten) zur Durchführung Ihres Auftrags (Art. 6 Abs. 1 lit. b DSGVO), zur Dokumentation des Fahrzeugzustands (berechtigtes Interesse an Beweissicherung, Art. 6 Abs. 1 lit. f) und zur Erfüllung steuerlicher Aufbewahrungspflichten (Art. 6 Abs. 1 lit. c). Terminerinnerungen erhalten Sie per E-Mail oder, auf Wunsch, per WhatsApp. Empfänger sind unser E-Mail-Anbieter und unser Steuerberater; Rechnungsdaten bewahren wir 10 Jahre auf, übrige Daten löschen wir spätestens 3 Jahre nach dem letzten Auftrag. Sie haben das Recht auf Auskunft, Berichtigung, Löschung, Einschränkung, Datenübertragbarkeit und Widerspruch sowie auf Beschwerde bei einer Aufsichtsbehörde (für Bayern: Bayerisches Landesamt für Datenschutzaufsicht, Ansbach). Fotos Ihres Fahrzeugs verwenden wir nur mit Ihrer Einwilligung für Werbung; das Kennzeichen wird dabei unkenntlich gemacht.

Website-Formular zusätzlich: Hinweis, dass die Anfrage in unser Kundensystem übertragen wird, und bei Google-Ads-Kennung (gclid) ein Verweis auf die Werbeauswertung.

F. Auftragsverarbeiter und Drittlandtransfer

Dienst	Zweck	Personenbezug	Vertrag / Nachweis
E-Mail-Anbieter (z. B. IONOS, web.de, Google Workspace)	Versand von Erinnerungen, Angeboten, Rechnungen	ja	AV-Vertrag des Anbieters (bei web.de/GMX: für gewerbliche Nutzung Geschäftskunden-Tarif prüfen)
Windsor.ai	Abruf von Google Ads, Meta Ads, GA4, Instagram; Import von Meta-Lead-Formularen	ja (Lead-Formulare)	AV-Vertrag von Windsor.ai (EU-Unternehmen)
Google (Ads, Analytics, Search Console, Places)	Werbe- und Suchdaten, Wettbewerberprofile	mittelbar (Analytics)	Google Ads Data Processing Terms, Google Analytics AV-Bedingungen, IP-Anonymisierung ist bei GA4 Standard
Meta (Lead Ads, Marketing API)	Kampagnenzahlen, Lead-Formulare	ja	Meta Data Processing Terms; Lead-Formulare enthalten Einwilligungstext der Kampagne

Dienst	Zweck	Personenbezug	Vertrag / Nachweis
Anthropic (KI-Assistent)	Auswertung von Kennzahlen; nur bei Freigabe Personenbezug	standardmäßig nein	Anthropic Commercial Terms inkl. Data Processing Addendum; Daten werden vertragsgemäß nicht zum Training verwendet; Standardvertragsklauseln für USA
Cloudflare Tunnel / Hosting-Anbieter (bei Internetzugriff)	Erreichbarkeit	ja (Transport)	AV-Vertrag des Anbieters; Serverstandort EU wählen
Cloud für Sicherungskopien (OneDrive, Google Drive)	Backup	ja	AV-Vertrag im Geschäftstarif; Sicherung zusätzlich verschlüsselt ablegen (z. B. Cryptomator)
Apple (bei Nutzung der Home-Bildschirm-App)	kein Datenfluss an Apple	nein	–

G. Technische und organisatorische Maßnahmen (TOM)

Zutritt/Zugang/Zugriff: Laptop mit BitLocker, Anmeldung mit Windows-Kennwort und Bildschirmsperre nach 5 Minuten; Manager-Konten personengebunden mit Passwortsrichtlinie, Sperre nach Fehlversuchen, 2FA (für Administratoren erzwingbar); Rollen mit minimalen Rechten; Sitzungsablauf. **Weitergabe:** HTTPS bei Internetzugriff (HSTS, Secure-Cookies); E-Mail-Versand über verschlüsselte SMTP-Verbindung; keine Daten an Dritte ohne AV-Vertrag; KI-Assistent pseudonymisiert. **Eingabe:** Audit-Log jeder Anlage, Änderung, Löschung, jedes Exports mit Benutzer und Zeit. **Verfügbarkeit:** tägliche Sicherung, Aufbewahrung von Versionen, dokumentierte Wiederherstellung, Update-Prozess mit Sicherung davor, Kopie der Sicherungen außer Haus. **Trennung:** Mandantentrennung in der Datenbank, getrennte Dateiordner, Testsystem mit Demo-Daten (niemals echte Kundendaten für Tests). **Datenminimierung/Löschung:** Löschkonzept mit automatischen Fristen, Anonymisierung statt Löschung bei Aufbewahrungspflicht, Auskunftsexport per Klick.

H. Löschkonzept (Kurzfassung)

Datenart	Frist	Auslöser
Verlorene Leads	12 Monate nach letzter Änderung	automatisch täglich
Unbeantwortete Leads	24 Monate	automatisch täglich
E-Mail-Versandprotokoll	12 Monate	automatisch täglich
Audit-Log	24 Monate	automatisch täglich
Job-Protokoll	90 Tage	automatisch täglich
Sitzungen	Ablauf 8 h Leerlauf / 30 Tage	automatisch täglich
Kunde ohne Belege	sofort auf Anfrage	manuell „Endgültig löschen“
Kunde mit Belegen	Anonymisierung sofort; Belege 8/10 Jahre	manuell „Endgültig löschen“ → Anonymisierung
Inaktive Kunden	optional nach N Jahren	automatisch, wenn eingestellt
Fotos/Protokolle	mit dem Kunden; sonst spätestens 3 Jahre nach Auftrag (organisatorisch prüfen)	manuell / mit Anonymisierung
Sicherungen	14 automatische, 20 manuelle	automatisch beim Erstellen

Hinweis: Gelöschte Daten können in älteren Sicherungen noch bis zu deren Ablauf enthalten sein. Das ist zulässig, wenn Sicherungen nur zur Wiederherstellung dienen und nach Ablauf gelöscht werden. Nach einer Wiederherstellung müssen zwischenzeitliche Löschungen erneut ausgeführt werden (Audit-Log prüfen: Aktionen `customer.anonymize`).

I. Vorgehen bei einer Datenpanne

1. Sofort: Zugang sperren (Benutzer deaktivieren, Passwörter und `APP_SECRET` wechseln, Sitzungen werden dadurch ungültig), Laptop vom Netz trennen, wenn Schadsoftware vermutet wird.

2. Innerhalb von 24 Stunden: Umfang feststellen (Audit-Log, Versandprotokoll, Sicherungen), betroffene Personen und Datenarten auflisten.
3. Innerhalb von 72 Stunden: Meldung an die Aufsichtsbehörde (Bayern: BayLDA, Online-Formular), wenn ein Risiko für Betroffene besteht; bei hohem Risiko auch Betroffene informieren (Art. 34).
4. Dokumentieren, auch wenn keine Meldung nötig war (Art. 33 Abs. 5).

J. Restrisiken und Empfehlungen

1. **Laptop als Server:** Diebstahl oder Defekt trifft Betrieb und Daten gleichzeitig. BitLocker und externe Sicherungskopie sind Pflicht; ein kleiner Server in der EU mit HTTPS ist die robustere Lösung.
2. **HTTP im WLAN:** vertretbar im eigenen, WPA2/WPA3-gesicherten Werkstattnetz; Gästernetz trennen.
3. **WhatsApp-Erinnerungen:** Versand erfolgt nur durch manuellen Klick auf dem Handy des Mitarbeiters. Für WhatsApp Business gelten eigene Datenschutzbedingungen; im Zweifel E-Mail bevorzugen.
4. **KI-Assistent mit Personenbezug:** nur nach AV-Vertrag mit Anthropic aktivieren.
5. **Verkauf an andere Betriebe:** Carcura wird Auftragsverarbeiter, benötigt AV-Verträge, TOM-Nachweis und eine Datenschutz-Folgenabschätzung prüfen lassen. Vor dem ersten zahlenden Kunden Rechtsanwalt mit Schwerpunkt IT-Recht einbinden.